

ROSS TAX PREPARATION LLC

Information Security Policy

Version 1.0 | Effective Date: January 1, 2025

1. Purpose

This Information Security Policy establishes the framework, principles, and requirements for protecting the confidentiality, integrity, and availability of information assets at Ross Tax Preparation LLC ("the Company"). This policy applies to all employees, contractors, and third-party service providers who have access to the Company's information systems and data.

2. Scope

This policy covers:

- All digital and physical information assets
- All production systems, databases, and applications
- Consumer financial data received through third-party integrations (including Plaid)
- Mobile applications (iOS/Android) and web applications
- All cloud infrastructure (Railway, Vercel, MongoDB Atlas)

3. Information Security Governance

3.1 Responsible Party

- Information Security Officer: Yoandy Ross, Managing Member
- Contact: yoandyross@rosstaxpreparation.com
- Phone: (806) 934-2018
- Address: 305 Bruce Ave, Dumas, TX 79029

3.2 Risk Management

The Company conducts ongoing risk assessments to identify, evaluate, and mitigate information security risks.

This includes:

- Regular review of access controls
- Monitoring of cloud infrastructure security alerts
- Evaluation of third-party service provider security posture
- Incident tracking and response

4. Access Control

4.1 Principle of Least Privilege

Access to production systems and consumer data is granted based on the principle of least privilege. Users are given only the minimum level of access necessary to perform their job functions.

4.2 Role-Based Access Control (RBAC)

The Company implements RBAC across all systems:

- Admin: Full access to administrative functions and client data management
- Office Assistant: Limited access to client-facing operations
- Client: Access restricted to their own data only

4.3 Authentication

- All production systems require multi-factor authentication (MFA)
- Consumer-facing applications support SMS-based two-factor authentication (2FA)
- API access is controlled via session tokens with automatic expiration
- Service-to-service communication uses API keys stored in encrypted environment variables

4.4 Access Reviews

Access to production systems is reviewed quarterly to ensure that access rights remain appropriate and that terminated employees/contractors have had their access revoked.

5. Data Protection

5.1 Encryption in Transit

All data transmitted between clients and servers is encrypted using TLS 1.2 or higher. This includes:

- HTTPS for all web and API communications
- Encrypted connections to MongoDB Atlas (TLS/SSL)
- Secure WebSocket connections for real-time features

5.2 Encryption at Rest

Consumer data is encrypted at rest using:

- MongoDB Atlas: AES-256 encryption for all stored data
- Railway: Volume-level encryption for all server instances
- Vercel: Encrypted deployment storage

5.3 Data Classification

Data is classified into the following categories:

- Confidential: Social Security Numbers, bank account numbers, routing numbers, tax returns
- Private: Consumer names, addresses, phone numbers, email addresses
- Internal: Business operations data, employee information
- Public: Marketing materials, public-facing content

5.4 Sensitive Data Handling

- Social Security Numbers are stored with only the last 4 digits visible in administrative interfaces
- Bank account and routing numbers are stored in a dedicated secured collection
- Plaid access tokens are stored encrypted in the database and never exposed to the frontend
- Session tokens expire automatically after the configured timeout period

6. Infrastructure Security

6.1 Cloud Infrastructure

All production services run on managed cloud platforms:

- Backend API: Railway (automated container orchestration)
- Web Application: Vercel (serverless deployment)
- Database: MongoDB Atlas (managed database service)

- Mobile App: Apple App Store / Google Play Store (managed distribution)

6.2 Network Security

- All cloud services are configured with network-level access controls
- Database access is restricted to authorized application servers only
- No direct SSH access to production servers
- All traffic routed through HTTPS with valid SSL certificates

6.3 Monitoring and Logging

- Application-level logging captures all API requests and responses
- Railway provides real-time deployment logs and health monitoring
- MongoDB Atlas provides database access audit logs
- Alert mechanisms are configured for anomalous activity detection

7. Vulnerability Management

7.1 Patch Management

- Dependencies are regularly updated to address known vulnerabilities
- Automated dependency scanning is performed during the CI/CD pipeline
- Critical security patches are applied within 72 hours of disclosure

7.2 Vulnerability Scanning

- Cloud platform providers (Railway, Vercel, MongoDB Atlas) perform automated vulnerability scanning
- Application dependencies are monitored for known vulnerabilities
- GitHub Dependabot alerts are enabled for all repositories

8. Incident Response

8.1 Incident Detection

Security incidents are detected through:

- Automated monitoring and alerting systems
- User reports and complaints
- Regular log reviews
- Third-party notification (e.g., platform security advisories)

8.2 Incident Response Process

1. Identification: Confirm and classify the security incident
2. Containment: Take immediate action to limit the impact
3. Eradication: Remove the root cause of the incident
4. Recovery: Restore affected systems and data
5. Post-Incident Review: Document lessons learned and improve controls

8.3 Notification

In the event of a data breach involving consumer financial data:

- Affected consumers will be notified within 72 hours
- Relevant regulatory bodies will be notified as required by law
- Third-party integration partners (including Plaid) will be notified promptly

9. Third-Party Risk Management

9.1 Vendor Assessment

Before engaging with third-party service providers that will have access to consumer data, the Company evaluates:

- Security certifications (SOC 2, ISO 27001, etc.)
- Data handling and privacy practices
- Incident response capabilities
- Compliance with applicable regulations

9.2 Current Third-Party Providers

Provider	Purpose	Security Certifications
Plaid	Bank account linking	SOC 2 Type II, ISO 27001
MongoDB Atlas	Database hosting	SOC 2 Type II, ISO 27001, HIPAA
Railway	Backend hosting	SOC 2 Type II
Vercel	Frontend hosting	SOC 2 Type II
Apple	Mobile app distribution	ISO 27001, SOC 2

10. Privacy and Data Retention

10.1 Privacy Policy

The Company maintains a publicly available privacy policy that describes:

- What data is collected and why
- How data is used, stored, and protected
- Consumer rights regarding their data
- Contact information for privacy inquiries

10.2 Consumer Consent

- Consumers provide explicit consent during account registration
- Plaid Link integration obtains separate consent for bank data access
- Consumers can withdraw consent at any time

10.3 Data Retention

- Active consumer data is retained for the duration of the business relationship
- Tax-related documents are retained for 7 years per IRS requirements
- Plaid access tokens are retained only while the bank connection is active
- Upon account deletion, consumer data is removed within 30 days (except where legally required to retain)

10.4 Data Deletion

Consumers may request deletion of their data by:

- Contacting support at yoandyross@rosstaxpreparation.com
- Calling (806) 934-2018
- Requesting through the mobile application

11. Employee Security Awareness

11.1 Training

All employees and contractors receive security awareness training that covers:

- Phishing and social engineering awareness
- Proper data handling procedures
- Incident reporting procedures
- Password and authentication best practices

11.2 Acceptable Use

Employees must:

- Use strong, unique passwords for all work accounts
- Enable MFA on all systems that support it
- Report suspected security incidents immediately
- Not share credentials or access tokens

12. Business Continuity

12.1 Data Backup

- MongoDB Atlas performs automated daily backups with point-in-time recovery
- Application code is version-controlled in GitHub with full history
- Configuration files are securely stored and documented

12.2 Disaster Recovery

- Cloud infrastructure allows for rapid redeployment in case of failure
- Database can be restored from backup within 1 hour
- Application services can be redeployed within 30 minutes

13. Policy Review

This policy is reviewed and updated annually, or more frequently as needed in response to:

- Changes in the business environment
- New regulatory requirements
- Security incidents or near-misses
- Changes in technology or infrastructure

Approved by:

Yoandy Ross, Managing Member

Ross Tax Preparation LLC

Date: January 1, 2025

Next Review Date: January 1, 2026